

Clase 328 — Gestión de riesgos cuantitativa y continuidad avanzada

Parte: **17 — Profundización para certificaciones** · Fuente: *(ISC)² CISSP OSG — Security and Risk Management · The Open Group — Open FAIR (O-RT, O-RA) · NIST SP 800-34 (Contingency Planning)* 🕒
Duración estimada: **140 min** · Nivel: **Avanzado**

Objetivo

Pasar del riesgo "por colores" (alto/medio/bajo) al riesgo **medido en dinero**. Esta clase enseña a cuantificar el riesgo con el modelo **FAIR** (Factor Analysis of Information Risk) y las métricas clásicas de CISSP —**SLE, ARO y ALE**—, a manejar la incertidumbre con **simulación de Monte Carlo**, y a conectar ese análisis con la **continuidad del negocio**: un **BIA** (Business Impact Analysis) que fija **RTO y RPO**, y las estrategias de **continuidad (BCP)** y **recuperación ante desastres (DR)**. Es el núcleo cuantitativo del dominio *Security and Risk Management* de CISSP.

Resultados de aprendizaje

Al finalizar, el alumno podrá:

1. **Calcular** la exposición anual de un riesgo con SLE, ARO y ALE, y justificar cada factor.
2. **Descomponer** un escenario de riesgo con la taxonomía FAIR (frecuencia de eventos de pérdida × magnitud de pérdida).
3. **Modelar** la incertidumbre con distribuciones y una simulación de Monte Carlo para obtener un rango de pérdida, no un número único.
4. **Ejecutar** un BIA que priorice procesos y derive RTO, RPO y MTD para cada uno.
5. **Diseñar** una estrategia de continuidad y DR (sitios, backups, orden de recuperación) coherente con los RTO/RPO fijados.

Temas

#	Tema	Por qué importa
1	Riesgo cualitativo vs cuantitativo	Cada uno responde preguntas distintas; el cuantitativo prioriza inversión
2	SLE, ARO, ALE	Métricas base de CISSP para expresar riesgo anual en dinero
3	Taxonomía FAIR	Descompone el riesgo en factores medibles y defendibles
4	Distribuciones e incertidumbre (PERT/lognormal)	El riesgo es un rango, no un punto
5	Simulación de Monte Carlo	Convierte estimaciones inciertas en una curva de pérdida
6	ROSI y decisión de control	Compara el coste del control contra la reducción de ALE
7	BIA: procesos críticos, MTD, RTO, RPO	Fija cuánto puede parar y cuántos datos se pueden perder
8	Estrategias de continuidad y DR	Traduce los objetivos en sitios, backups y planes de recuperación

Definiciones y características

- **SLE (Single Loss Expectancy):** pérdida esperada de un solo evento. $SLE = \text{valor del activo (AV)} \times \text{factor de exposición (EF)}$. Característica clave: mide el impacto de **un** incidente, no del año.
- **ARO (Annualized Rate of Occurrence):** número esperado de veces que el evento ocurre en un año (p. ej. 0,1 = una vez cada diez años). Característica clave: expresa la frecuencia como tasa anual.
- **ALE (Annualized Loss Expectancy):** pérdida esperada por año. $ALE = SLE \times ARO$. Característica clave: es la métrica que se compara contra el coste de los controles.
- **FAIR:** marco abierto (The Open Group) que descompone el **Riesgo = Frecuencia de eventos de pérdida (LEF) × Magnitud de pérdida (LM)**, y a su vez LEF en frecuencia de amenaza y vulnerabilidad. Característica clave: hace el análisis **repetible y defendible**, con definiciones consistentes.
- **Monte Carlo:** técnica que muestrea miles de veces las distribuciones de entrada para producir una distribución de salida. Característica clave: entrega **percentiles** (p. ej. pérdida en el percentil 90) en lugar de un único valor engañoso.
- **BIA (Business Impact Analysis):** análisis que identifica procesos críticos y el impacto —económico, legal, reputacional— de su interrupción en el tiempo. Característica clave: es la **entrada** que justifica las inversiones en continuidad.
- **RTO (Recovery Time Objective):** tiempo máximo tolerable para restaurar un proceso tras una interrupción. Característica clave: marca cuánta velocidad de recuperación hay que comprar.
- **RPO (Recovery Point Objective):** cantidad máxima de datos (en tiempo) que se puede perder; define la frecuencia de backup/replicación. Característica clave: RPO pequeño exige replicación casi continua.
- **MTD (Maximum Tolerable Downtime):** tiempo total tras el cual el daño es irreversible para el negocio; $RTO + \text{tiempo de recuperación del trabajo} \leq MTD$. Característica clave: es el techo que ningún RTO puede superar.

Herramientas y preparación

Ejercicio **analítico/GRC** — no hay explotación; se construyen modelos con datos de tu propia organización o de un caso simulado:

- **Hoja de cálculo** (Excel/LibreOffice/Google Sheets) para SLE/ARO/ALE y tablas del BIA.
- **Simulación de Monte Carlo**: complemento como *Data Table* de Excel, o un script en **Python** con `numpy` (`numpy.random.triangular`, `lognormal`) y `matplotlib` para graficar la curva de pérdida.
- **Plantilla FAIR**: hoja con los factores de la taxonomía (LEF, TEF, Vulnerability, LM primaria y secundaria). La guía **Open FAIR** de The Open Group es la referencia pública.
- **Plantilla de BIA**: inventario de procesos, dependencias, impacto por ventana temporal, RTO/RPO/MTD.
- Fuentes de estimación **reales**: histórico de incidentes, informes de la industria (p. ej. estudios de coste de brecha), y opinión experta calibrada.

Nota: la calidad del modelo depende de las estimaciones. Documenta los supuestos y usa **rangos calibrados** (mín/más probable/máx) en vez de números inventados con falsa precisión.

Laboratorio guiado — Modelar un riesgo con FAIR + Monte Carlo y derivar la continuidad

Ejercicio aplicado: cuantificas un riesgo de ransomware sobre un sistema crítico y usas el resultado para diseñar su continuidad.

1. **Define el escenario.** Elige un activo (p. ej. la base de datos de pedidos), la amenaza (ransomware) y el efecto (indisponibilidad + posible exfiltración). Escríbelo en una frase de riesgo clara.
2. **Cálculo clásico ALE.** Estima `AV` (valor del activo/proceso), `EF` (% de pérdida si ocurre) → `SLE`. Estima `ARO` a partir del histórico y la exposición → $ALE = SLE \times ARO$. Anota los supuestos.
3. **Descompón con FAIR.** Rellena la taxonomía: frecuencia de contacto/amenaza (TEF), vulnerabilidad, y magnitud de pérdida separando **pérdida primaria** (respuesta, restauración) y **secundaria** (multas, reputación, clientes).
4. **Asigna distribuciones.** En lugar de puntos, define rangos calibrados (mínimo, más probable, máximo) para LEF y LM. Usa una distribución triangular o PERT.
5. **Corre Monte Carlo.** Simula 10.000 iteraciones muestreando las distribuciones y multiplicando LEF × LM. Grafica el histograma y extrae media, percentil 50 y percentil 90 de la pérdida anual.
6. **Decide el control (ROSI).** Propón un control (backups inmutables + segmentación). Estima cuánto reduce LEF o LM, recalcula el ALE mitigado y compara: $ROSI = (ALE_{antes} - ALE_{después} - coste_control) / coste_control$.
7. **Enlaza con el BIA.** Para el mismo proceso, completa el BIA: impacto por ventanas (1 h, 8 h, 24 h, 72 h) y deriva **RTO, RPO y MTD**. Comprueba que $RTO \leq MTD$.
8. **Diseña continuidad/DR.** Elige la estrategia acorde al RTO/RPO: tipo de sitio (frío/tibio/caliente o multi-región), esquema de backup (3-2-1, inmutable) y orden de recuperación según dependencias. Justifica el coste contra el ALE.
9. **Prueba en papel.** Redacta un *tabletop* del plan de DR: quién declara el desastre, secuencia de recuperación y criterio de "servicio restaurado".

Entregable: hoja con ALE clásico + modelo FAIR con curva de Monte Carlo (percentil 90), análisis ROSI del control, BIA con RTO/RPO/MTD y una estrategia de continuidad/DR justificada.

Ejercicios

1. Calcula el ALE de un escenario dado (AV, EF, ARO) y explica qué pasa con el ALE si el ARO se duplica.
2. Descompón un riesgo de fuga de datos con la taxonomía FAIR, separando pérdida primaria y secundaria.
3. Justifica por qué un único número de pérdida es engañoso y qué aporta reportar el percentil 90.
4. Construye un mini Monte Carlo (100 filas en hoja de cálculo o 20 líneas de Python) para una pérdida triangular.
5. Dado un proceso con MTD de 24 h, propón RTO y RPO coherentes y la estrategia de sitio que los cumple.
6. Compara tres controles por su ROSI y recomienda cuál financiar primero.

Reto verificable

Reto: entrega un análisis de riesgo cuantitativo de un proceso crítico que termine en una estrategia de continuidad justificada.

Criterio de aceptación:

- Hay un **ALE clásico** ($SLE \times ARO$) con supuestos documentados **y** un modelo **FAIR** de los mismos factores.
- La incertidumbre se modela con **distribuciones** y una **simulación de Monte Carlo**, reportando al menos el **percentil 90** de pérdida anual.
- Existe un **análisis ROSI** que compara el coste del control contra la reducción de ALE, con una recomendación clara.
- El **BIA** deriva **RTO, RPO y MTD** del proceso, y se verifica que **$RTO \leq MTD$** .
- La estrategia de **continuidad/DR** (sitio, backups, orden de recuperación) es **coherente con los RTO/RPO** y su coste se justifica frente al ALE.

Errores comunes

Síntoma / mensaje	Causa y cómo arreglar
"El ALE me dio un número exacto de 47.312 €"	Falsa precisión. El riesgo es un rango; reporta percentiles con Monte Carlo, no un punto.
"Puse ARO = 1 porque 'seguro pasa'"	Confundes certeza con frecuencia. ARO es tasa anual estimada; usa histórico y rangos.
"Mi FAIR mezcla pérdida primaria y secundaria"	Se sobreestima o infravalora el impacto. Sepáralas: respuesta/restauración vs multas/reputación.
"Definí RTO = 4 h pero el MTD es 2 h"	RTO no puede superar el MTD. Ajusta el RTO o invierte en recuperación más rápida.
"Compré un sitio caliente para un proceso no crítico"	Sobreinversión sin BIA. Deja que el BIA priorice; el gasto en DR sigue al impacto.
"Tengo backups pero nunca probé restaurar"	RPO teórico ≠ recuperación real. Prueba la restauración; un backup no verificado no cumple el RPO.

Preguntas frecuentes

? ¿Cuándo uso análisis cualitativo y cuándo cuantitativo? El cualitativo (matriz de probabilidad × impacto) es rápido para triar y priorizar muchos riesgos. El cuantitativo (ALE/FAIR/Monte Carlo) se reserva para las decisiones donde el dinero importa: justificar una inversión, elegir entre controles o reportar a dirección. Suelen usarse juntos: cualitativo para filtrar, cuantitativo para los pocos que llegan al comité.

? ¿FAIR reemplaza a SLE/ARO/ALE? No los contradice: los estructura. FAIR descompone la frecuencia y la magnitud en factores más estimables y define un vocabulario consistente. El resultado sigue siendo una pérdida anualizada, pero con una trazabilidad que un ALE improvisado no tiene.

? ¿Por qué Monte Carlo y no una simple multiplicación? Porque las entradas son inciertas. Multiplicar los valores "más probables" ignora las colas: la simulación combina las distribuciones y muestra la probabilidad de escenarios extremos (el percentil 90/95), que es justo lo que preocupa a un comité de riesgos.

? ¿Qué diferencia hay entre RTO y RPO? RTO mira **hacia adelante**: cuánto tiempo puedo tardar en volver a funcionar. RPO mira **hacia atrás**: cuántos datos (medidos en tiempo) puedo permitirme perder. Un RPO de 15 min exige replicación frecuente; un RTO de 1 h exige capacidad de arranque casi inmediata.

Referencias

- Chapple, Stewart & Gibson. *(ISC)² CISSP Official Study Guide*, 9.^a ed., Sybex — *Security and Risk Management y Business Continuity Planning*.
- The Open Group. *Risk Taxonomy (O-RT) y Risk Analysis (O-RA)* — estándar **Open FAIR** — publications.opengroup.org.
- Freund, J. & Jones, J. *Measuring and Managing Information Risk: A FAIR Approach*, Butterworth-Heinemann.
- NIST. *Contingency Planning Guide for Federal Information Systems* — [SP 800-34 Rev.1](#).

- Hubbard, D. & Seiersen, R. *How to Measure Anything in Cybersecurity Risk*, Wiley — estimación calibrada y Monte Carlo.



Material descargable

-  [Guía en PDF](#) — versión imprimible de esta clase.
-  [Presentación \(PPTX\)](#) — deck para proyectar en clase.



Siguiente clase

[Clase 329 - Arquitectura de seguridad empresarial y Zero Trust](#)